Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

Implementation Solution Guide

Version 1.0.0 · 2026-07-10

Contents

Executive Summary — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 5

What you get . . . 5

What this delivers . . . 5

The standard deployment model . . . 6

Outcome . . . 6

1. Solution Overview — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 6

Why passwordless, and why phishing-resistant . . . 6

FIDO2 and WebAuthn — the standard underneath . . . 7

The two shapes: FIDO2 security keys and passkeys . . . 7

The authentication methods policy . . . 7

The registration campaign . . . 7

Conditional Access — where enforcement lives . . . 8

Fallback and recovery . . . 8

What you can control . . . 8

Benefits . . . 8

Limitations (be honest with buyers) . . . 8

The standard deployment model . . . 9

Authentication and connections used . . . 9

2. Requirements Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 9

2.1 Entra ID licensing for enforcement . . . 10

2.2 Administrative roles . . . 10

2.3 FIDO2 security keys (for the key-based users) . . . 10

2.4 Microsoft Authenticator (for passkey / device-bound passkeys) . . . 10

2.5 Temporary Access Pass (TAP) enabled . . . 10

2.6 Pilot and rollout groups . . . 11

2.7 Sensitive-apps and privileged-users decision . . . 11

2.8 Microsoft Graph PowerShell SDK . . . 11

2.9 Break-glass accounts (from global requirements) . . . 11

Checklist . . . 11

Global Requirements — Entra ID Solutions (category-level) 12

G1. Microsoft Entra ID tenant . . . 12

G2. Entra ID licensing (P1, P2 where noted) . . . 12

G3. Administrative roles . . . 12

G4. Break-glass (emergency access) accounts . . . 12
G5. Healthy on-premises Active Directory . . . 13
G6. An Entra Connect host server . . . 13
G7. UPN / domain hygiene . . . 13
G8. Network access to Microsoft cloud endpoints . . . 13
GCC High Parity & Compliance Notes — Passwordless & Passkey (FIDO2) Rollout 13
National cloud endpoints . . . 14
Feature-parity considerations . . . 14
Compliance & data-residency context (why GCC High) . . . 15
DoD (IL5) note . . . 16
3. Implementation Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 16
Step 1 — Create the rollout and campaign groups . . . 17
Step 2 — Assess the current state (baseline) . . . 17
Step 3 — Enable Temporary Access Pass (the safety net first) . . . 17
Step 4 — Enable the passwordless methods for the pilot . . . 18
Step 5 — Turn on the registration campaign for the pilot . . . 18
Step 6 — Require phishing-resistant MFA for admins (report-only first) . . . 18
Step 7 — Pilot: register and sign in passwordless . . . 19
Step 8 — Validate the pilot . . . 19
Step 9 — Enforce for admins, then expand in waves . . . 19
Step 10 — Operate the recovery runbook . . . 20
5. Testing Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 20
Test 1 — Methods policy is correct . . . 20
Test 2 — Temporary Access Pass can be issued and used . . . 21
Test 3 — FIDO2 security key registration and sign-in . . . 21
Test 4 — Passkey (Authenticator) registration and sign-in . . . 21
Test 5 — Registration campaign nudges the pilot . . . 21
Test 6 — Phishing-resistant CA policy evaluates (report-only) . . . 21
Test 7 — Enforcement requires phishing-resistant MFA . . . 21
Test 8 — Break-glass is never blocked . . . 21
Test 9 — Adoption is measurable . . . 22
Pass/fail gate . . . 22
6. Troubleshooting Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra 22
A. Discovery or validation errors . . . 22
B. The passkey (Authenticator) option is missing . . . 23

C. FIDO2 security-key registration fails . . . 23
D. User can't register — no way to start . . . 23
E. Registration campaign not prompting . . . 24
F. Conditional Access policy blocks the wrong people (or nobody) . . . 24
G. "Authentication strength" not requiring passwordless . . . 24
H. Weak-method retirement caused lock-outs . . . 24
I. Diagnostics quick reference . . . 24
J. When to escalate . . . 25
7. Best Practices — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra 25
Where to go next . . . 26
8. Deliverables Summary — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High) 26
Documentation . . . 26
PowerShell scripts . . . 27
What the buyer receives . . . 27
Outcome . . . 28
Appendix A — PowerShell Scripts 29

Executive Summary — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

White-label · Entra ID Solutions · **US Government (GCC High) edition**

This is the **Government (GCC High)** edition for US public-sector and defense-industrial-base tenants running in Microsoft's US Government national cloud (Azure Government / GCC High). It mirrors the commercial passwordless method, adapted for the sovereign cloud — GCC High portals (`entra.microsoft.us` / `mysignins.microsoft.us`) and US Gov script endpoints (`Connect-MgGraph -Environment USGov`; DoD/IL5 uses `USGovDoD`). **Phishing-resistant MFA is a federal Zero Trust requirement:** OMB Memorandum **M-22-09** directs agencies to enforce phishing-resistant MFA (FIDO2 / WebAuthn), and **CMMC 2.0** drives the same for the defense-industrial-base — making this rollout a direct mandate-satisfying control. Because passkey / FIDO2 method availability in GCC High/DoD can lag commercial, every capability is flagged *"verify against current Microsoft Government documentation"* — see `gcc-high-parity-notes.md` for endpoints, parity, and the FedRAMP High / DoD IL4-IL5 / CMMC / M-22-09 context.

Passwords are the single largest attack surface in your tenant. They get phished, reused, sprayed, and reset — and even most "MFA" is still phishable, because a code typed into a fake sign-in page works just as well for the attacker. The fix is to remove the shared secret entirely: move users to **phishing-resistant, passwordless sign-in** using FIDO2 security keys and device-bound passkeys in Microsoft Authenticator, where the credential never leaves the device and cannot be replayed against a look-alike site.

This is a complete, deploy-it-today package for rolling out passwordless authentication in Microsoft Entra, written for an administrator with no prior passwordless experience. It gives you a repeatable way to enable the right authentication methods, drive users to register through a registration campaign and clear comms, require phishing-resistant MFA for the people who matter most through Conditional Access, and keep a fallback and lost-key runbook so nobody is ever locked out.

What you get

- A plain-language Solution Overview of how passwordless works in Entra — FIDO2 / WebAuthn, passkeys

(device-bound vs. synced), the authentication methods policy, the registration campaign, and how Conditional Access enforces phishing-resistant MFA.

- A Requirements Guide with verify / implement-if-missing for every solution-specific prerequisite.
- An Implementation Guide of precise, click-by-click Entra steps in the required order, pilot-first.
- Five PowerShell scripts for authentication-method discovery, adoption reporting, a safe

methods-policy change (preview by default), rollout-group targeting, and a validation check.

- Testing, Troubleshooting, and Best-Practices guides for a confident, staged rollout.

What this delivers

A tenant where the users who matter most sign in without a password at all — a hardware-backed FIDO2 key or a device-bound passkey they cannot be phished out of — with weak, phishable methods retired, a

registration campaign moving the rest of the organization across, and a documented recovery path for a lost or broken key, proven on a pilot group before you touch everyone.

The standard deployment model

Assess -> Configure -> Pilot -> Validate -> Expand.

Outcome

Phishing-resistant, passwordless sign-in across the tenant — the password attack surface removed for admins and sensitive apps first, then expanded organization-wide, with a fallback and lost-key runbook so the rollout never locks anyone out.

> *Some passkey capabilities (device-bound passkeys in Authenticator, synced-passkey handling) have shipped and changed on Microsoft's schedule,* ***and passkey / FIDO2 method availability in GCC High and DoD can lag the commercial cloud.*** *Where a feature may be in preview, gated by tenant configuration, or delayed/unavailable in the government cloud this package flags it — *verify current availability for your GCC High (or DoD) tenant against current Microsoft Government documentation* before you rely on it.*

1. Solution Overview — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

> ***Government (GCC High) edition.*** *This is the US-public-sector / defense-industrial-base edition, built for Microsoft's US Government national cloud (Azure Government / GCC High). It mirrors the commercial passwordless method exactly, adapted for the sovereign cloud: the GCC High Entra admin center (*`entra.microsoft.us`*), the GCC High security-info portal (*`mysignins.microsoft.us`*), and US Gov script endpoints (*`Connect-MgGraph -Environment USGov`*; DoD/IL5 uses* `USGovDoD` */* `dod-graph.microsoft.us`*).* ***Why this is a strong government driver:*** *phishing-resistant MFA is a* ***federal Zero Trust requirement****. OMB Memorandum* ***M-22-09*** *(*Moving the U.S. Government Toward Zero Trust Cybersecurity Principles*) directs agencies to enforce phishing-resistant MFA (explicitly citing FIDO2 / WebAuthn and PIV) for staff, contractors, and partners — exactly the FIDO2 security keys and passkeys this rollout deploys. For* ***defense-industrial-base*** *contractors,* ***CMMC 2.0*** *Identification & Authentication (IA) practices likewise push toward phishing-resistant authentication. This edition delivers the technical rollout that satisfies those mandates in the government cloud. Because GCC High and DoD can* ***lag commercial in feature availability*** *— particularly for newer* ***passkey / FIDO2 method*** *capabilities — treat every capability below as* ***"verify against current Microsoft Government documentation."*** *See* `gcc-high-parity-notes.md` *for endpoints, parity, and the FedRAMP / DoD / CMMC / M-22-09 context.*

Why passwordless, and why phishing-resistant

A password is a shared secret: the user knows it, the service stores a verifier for it, and anything that can trick the user into typing it — a fake sign-in page, a proxy in the middle — captures it. Adding a one-time code or a push approval helps, but most of it is still phishable: an attacker who relays your login in real time (adversary-in-the-middle) collects the code or triggers the push and walks in. Phishing-resistant authentication removes the shared secret. The credential is a private key that never leaves the user's

device or security key, and it is cryptographically bound to the real sign-in domain — so a look-alike site gets nothing it can replay.

FIDO2 and WebAuthn — the standard underneath

FIDO2 (with the WebAuthn browser standard) is the open standard Entra uses for phishing-resistant sign-in. At registration the device generates a public/private key pair for a specific relying party (here, Microsoft Entra); the private key stays in secure hardware and the public key is stored against the user in the directory. At sign-in the device proves possession of the private key with a local gesture (PIN, fingerprint, face), and the browser only completes the ceremony for the genuine origin. There is no secret to phish, spray, or reuse.

The two shapes: FIDO2 security keys and passkeys

This rollout uses two forms of the same technology:

- **FIDO2 security keys** — a physical hardware key (USB, NFC, or Lightning) the user taps or inserts. Ideal for admins, shared/kiosk workstations, and anyone who needs a portable credential not tied to one phone. Managed under the **FIDO2 security key** authentication method.
- **Passkeys in Microsoft Authenticator** — a **device-bound passkey** stored in the Authenticator app on the user's phone; the phone becomes the phishing-resistant credential. Managed under the **Passkey (FIDO2)** / Microsoft Authenticator passwordless method. This is the lowest-friction option for the general workforce because most users already carry a phone.

> *Passkey behavior in Authenticator (device-bound passkeys, and how synced consumer passkeys are treated) has shipped and evolved on Microsoft's timeline, **and passkey / FIDO2 method availability in GCC High and DoD can lag the commercial cloud.** *Verify current availability and any preview status for your GCC High (or DoD) tenant against current Microsoft Government documentation* under the authentication methods policy before committing a wave to a specific passkey type — do not assume commercial parity.*

The authentication methods policy

Entra decides which methods a user may register and use through the **authentication methods policy** (`Entra -> Identity -> Protection -> Authentication methods -> Policies`). Each method — FIDO2 security key, Passkey (Authenticator), Microsoft Authenticator, SMS, Voice call, Temporary Access Pass, etc. — is enabled or disabled and can be **targeted at specific groups**. This is what lets you turn passwordless on for a pilot group first, and — later — retire weak, phishable methods (SMS text and voice call) by scoping them out. A **Temporary Access Pass (TAP)** is a time-limited passcode an admin issues so a user can bootstrap their first passwordless credential (or recover) without a password.

The registration campaign

Enabling a method does not register users — they have to enroll. A **registration campaign** nudges users to set up a stronger method (passkey / Authenticator) during sign-in, so adoption happens by itself instead of one help-desk ticket at a time. You scope the campaign to a group, so each rollout wave gets nudged

when its turn comes.

Conditional Access — where enforcement lives

Enabling and registering passwordless is only half the job; you still have to **require** it for the people who matter. Conditional Access can grant access only when the sign-in used a **phishing-resistant** method, using the built-in **Authentication Strengths** control (the `Phishing-resistant MFA` strength). You apply that first to administrators and sensitive apps, so privileged access is passwordless-only, then widen the scope as adoption grows. Everything is piloted in **report-only** first so you can see who a policy *would* have blocked before it actually blocks anyone.

Fallback and recovery

Hardware gets lost and phones get replaced, so a passwordless rollout must include a recovery path or it will lock people out. The standard fallback is a **Temporary Access Pass** issued by the help desk (or an admin) to let a user register a new key/passkey, plus a documented lost-key runbook: revoke the lost credential, verify identity, issue a TAP, re-register. Break-glass accounts stay excluded from the enforcement policies at all times (global requirement G4).

What you can control

• Which methods are enabled, and for which groups — FIDO2 security key, Passkey (Authenticator), Authenticator, TAP, and the weak methods you will retire (SMS, Voice).

• Who is driven to register, and when — through the registration campaign scoped per wave.

• Who is *required* to be phishing-resistant — through Conditional Access authentication strength, admins and sensitive apps first.

• The recovery path — TAP issuance and the lost-key runbook.

Benefits

• Security — the number-one payoff: the phishable shared secret is gone; adversary-in-the-middle and password attacks stop working against enrolled users.

• Lower friction — a tap or a glance instead of a password plus a code; fewer reset tickets.

• Least-privilege first — admins and sensitive apps become passwordless-only before the rest.

• Repeatability — a wave-based pattern you re-run for each group, not a one-time flag flip.

Limitations (be honest with buyers)

• Requiring a phishing-resistant method through Conditional Access, and using device-based grant controls, needs Entra ID P1 (risk-based conditions need P2). *Verify your licensing* (requirements).

• Retiring SMS/voice before users have registered a stronger method will lock them out — retirement is the last step, gated on adoption, and always staged behind report-only and a pilot.

• Some passkey capabilities may be in preview or gated per tenant, **and may be delayed or unavailable

in GCC High / DoD relative to commercial** — *verify current availability against current Microsoft Government documentation* before committing a wave.

• This delivers the technical rollout; the decision about which apps count as "sensitive" and which

users are "privileged" belongs to your security and business owners.

The standard deployment model

> *Assess the current methods and adoption -> Configure the authentication methods policy and Conditional Access (report-only) on a pilot group -> Pilot passwordless registration and sign-in -> Validate against pass/fail gates -> Expand in waves, then retire weak methods. repeatable pattern: Assess -> Configure -> Pilot -> Validate -> Expand.*

Authentication and connections used

• GCC High Microsoft Entra admin center (`https://entra.microsoft.us`) for the authentication methods

policy, registration campaign, Temporary Access Pass, and Conditional Access. *Verify the current GCC High portal URL against Microsoft Government documentation.*

• The GCC High security-info / My Sign-Ins portal (`https://mysignins.microsoft.us/security-info`) for

end-user credential registration. *Verify the current GCC High URL.*

• Microsoft Graph PowerShell SDK targeting the US Government cloud (`Connect-MgGraph -Environment USGov`;

DoD/IL5 uses `-Environment USGovDoD` / `dod-graph.microsoft.us`) for read-only discovery/validation/reporting and the safe, preview-by-default methods-policy change (scopes named in each script header).

2. Requirements Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

Verify every requirement before configuring. Each entry: Description / Why / Verify / Implement-if-missing. Category-wide prerequisites are in `global-requirements-entra-id-solutions.md` (tenant, licensing, admin roles, break-glass accounts, network access) — this guide adds only what is specific to a passwordless rollout.

> ***Government (GCC High) edition.*** *This edition targets Microsoft's US Government national cloud (Azure Government / GCC High). Portals are the GCC High endpoints (`entra.microsoft.us` / `mysignins.microsoft.us`) and scripts target the US Gov cloud (`Connect-MgGraph -Environment USGov`). Phishing-resistant MFA is a **federal Zero Trust requirement (OMB M-22-09)** and a **CMMC 2.0** driver for the defense-industrial-base. **Passkey / FIDO2 method availability in GCC High/DoD can lag commercial** — *verify against current Microsoft Government*

documentation. See* `gcc-high-parity-notes.md`.

2.1 Entra ID licensing for enforcement

Description: Microsoft Entra ID P1 to require a phishing-resistant method through Conditional Access; P2 if you also want risk-based conditions in the same policy set. Passwordless *registration and sign-in* work on any tenant; the Conditional Access *enforcement* needs P1+. Why: The Conditional Access authentication-strength grant control (require phishing-resistant MFA) is a P1 feature; sign-in/user-risk conditions are P2. Verify: GCC High M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2. *Government (GCC High/DoD) SKUs and availability differ from commercial — verify current availability for your tenant against current Microsoft Government documentation.* Implement: Assign M365 GCC High E3/E5, EMS E3/E5, or standalone Entra ID P1/P2 (government SKUs).

2.2 Administrative roles

Description: `Authentication Policy Administrator` to edit the authentication methods policy and registration campaign; `Conditional Access Administrator` (or `Security Administrator`) for the CA policies; `Authentication Administrator` to issue a Temporary Access Pass. Reserve `Global Administrator` for the first-time tenant-wide changes only. Why: These are the least-privilege roles that can enable methods, run the registration campaign, create the CA policy, and issue recovery TAPs — without over-granting. Verify: Entra -> `Roles and administrators`; confirm the operator holds `Authentication Policy Administrator` and `Conditional Access Administrator`. Implement: Assign the roles above; keep them in PIM/eligible where possible.

2.3 FIDO2 security keys (for the key-based users)

Description: Physical FIDO2 security keys for admins, shared workstations, and anyone who needs a portable credential. Prefer keys whose Authenticator Attestation GUID (AAGUID) you can allow-list. Why: Admins and kiosk/shared devices need a credential not tied to one personal phone; AAGUID allow-listing lets you accept only vetted key models. Verify: Keys are on hand for the pilot admins; you have their AAGUIDs (from the vendor) if you intend to restrict key models. Implement: Procure FIDO2 keys from a reputable vendor; record AAGUIDs for the optional allow-list in the FIDO2 method settings.

2.4 Microsoft Authenticator (for passkey / device-bound passkeys)

Description: A current version of Microsoft Authenticator on pilot users' phones for the Passkey (FIDO2) / passwordless-phone-sign-in method. Why: The lowest-friction workforce credential is a passkey in Authenticator; it requires the app installed, updated, and the device meeting the app's platform requirements. Verify: Pilot users have the latest Authenticator installed. *Verify current passkey availability and any preview status for your GCC High (or DoD) tenant against current Microsoft Government documentation* under the authentication methods policy — passkey/FIDO2 method availability in government clouds can lag commercial; do not assume parity. Implement: Deploy/update Microsoft Authenticator (via Intune or the app store) to pilot users before the registration campaign.

2.5 Temporary Access Pass (TAP) enabled

Description: The Temporary Access Pass method enabled in the authentication methods policy, scoped to the help desk / admins who will issue it. Why: TAP is how a user bootstraps their first passwordless

credential and how you recover a lost key without falling back to a password — it is the safety net for the whole rollout. Verify: Entra -> `Identity -> Protection -> Authentication methods -> Policies -> Temporary Access Pass` is enabled and targeted appropriately. Implement: Enable TAP; set lifetime/one-time options; scope issuance to the recovery operators.

2.6 Pilot and rollout groups

Description: Security groups for the staged rollout — a pilot group `Passwordless Rollout - Pilot - Pilot`, an admin group `Passwordless Rollout - Admins - Pilot`, and per-wave groups (for example `Passwordless Rollout - Wave1 - Expand`). Why: Every method-enable, registration campaign, and CA policy is targeted at a group so the rollout is staged and reversible — never tenant-wide on day one. Verify: The groups exist with the intended members; run `ENTPASSKEYG-Set-ScopeTargeting.ps1` to create/preview them. Implement: Create the groups with `ENTPASSKEYG-Set-ScopeTargeting.ps1` (see Implementation Step 1).

2.7 Sensitive-apps and privileged-users decision

Description: A documented list of which applications are "sensitive" and which users/roles are "privileged" — the first targets for required phishing-resistant MFA. Why: Conditional Access enforcement is scoped to these; the decision is a business/security call, not a technical default. Verify: Security/business owners have named the privileged roles and sensitive apps. Implement: Capture the list; it drives the CA policy scope in Implementation Step 6. This is a customer compliance/security decision — the guide provides the control, not the determination.

2.8 Microsoft Graph PowerShell SDK

Description: The Microsoft Graph PowerShell SDK on the operator workstation, consented to the scopes the scripts use. Why: Discovery, reporting, validation, and the safe methods-policy change read and (only when applied) write the authentication methods policy and registration state through Microsoft Graph. Verify: `Get-Module -ListAvailable Microsoft.Graph.Authentication` returns a version; a test `Connect-MgGraph -Environment USGov` (US Government cloud) succeeds against `graph.microsoft.us`. For DoD (IL5) use `-Environment USGovDoD` (`dod-graph.microsoft.us`). *Verify the correct cloud for your tenant.* Implement: `Install-Module Microsoft.Graph -Scope CurrentUser`; scripts request least privilege (`Policy.Read.All`, `UserAuthenticationMethod.Read.All`, `AuditLog.Read.All`, and — only for the policy change — `Policy.ReadWrite.AuthenticationMethod`).

2.9 Break-glass accounts (from global requirements)

Description: Two cloud-only emergency access accounts, excluded from the phishing-resistant CA policies at all times. Why: A method-policy or CA change could interfere with normal admin sign-in; break-glass restores access. See global requirement G4. Verify: Entra -> `Users`; two cloud-only `@onmicrosoft.com` admins exist and are excluded from the CA policies you create. Implement: Create them, exclude from the CA policies, store credentials securely, monitor sign-ins.

Checklist

- Entra ID P1/P2 licensing confirmed (P1 for CA enforcement, P2 for risk conditions)
- Roles assigned — `Authentication Policy Administrator`, `Conditional Access Administrator`, `Authentication Administrator`
- FIDO2 security keys on hand (AAGUIDs recorded if allow-listing)
- Microsoft Authenticator deployed/updated for pilot users (passkey availability verified)
- Temporary Access Pass method enabled and scoped to recovery operators
- Pilot / admin / wave groups created — `ENTPASSKEYG-Set-ScopeTargeting.ps1`
- Sensitive-apps and privileged-users list documented by the business
- Microsoft Graph PowerShell SDK installed and consented
- Two break-glass accounts created and excluded from the CA policies

Global Requirements — Entra ID Solutions (category-level)

These requirements apply to every solution in the Entra ID Solutions category. They are published once at the category level so individual listings stay small. Confirm these before deploying any identity solution. Each entry: Description / Why / Verify / Implement-if-missing.

> *The identity plane is high risk. A mistake here breaks sign-in for everyone, so every change is staged and a break-glass account is kept ready before you touch anything.*

G1. Microsoft Entra ID tenant

Description: An active Microsoft Entra ID tenant. Why: It is the cloud identity backbone every other identity service builds on. Verify: Sign in to `https://entra.microsoft.com` as an administrator. Implement: Create a Microsoft 365 or Azure subscription, which provisions a tenant.

G2. Entra ID licensing (P1, P2 where noted)

Description: Microsoft Entra ID P1 (or P2 for risk-based and PIM features). Why: Hybrid features such as seamless sign-in, password writeback, and Conditional Access require P1+. Verify: M365 admin center -> `Billing -> Licenses`; confirm Entra ID P1/P2 (often bundled in M365 E3/E5 or EMS). Implement: Assign M365 E3/E5, EMS E3/E5, or standalone Entra ID P1/P2.

G3. Administrative roles

Description: Hybrid Identity Administrator and Global Administrator for the operator. Why: Configuring directory synchronization and authentication methods needs these elevated roles. Verify: Entra -> `Roles and administrators`; confirm `Hybrid Identity Administrator` (and a Global Administrator for the one-time first-sync consent). Implement: Assign `Hybrid Identity Administrator`; reserve `Global Administrator` for tenant-wide and first-sync changes.

G4. Break-glass (emergency access) accounts

Description: At least two cloud-only emergency access accounts, excluded from Conditional Access and MFA-broad policies. Why: If sync, federation, or an auth-method change locks out admins, break-glass accounts get you back in. Verify: Entra -> `Users`; confirm two cloud-only accounts (`@onmicrosoft.com`) with strong stored credentials and documented use. Implement: Create two cloud-only Global Administrator accounts; exclude them from policies; store credentials securely and monitor sign-ins.

G5. Healthy on-premises Active Directory

Description: A functional AD forest/domain with healthy replication and DNS. Why: Synchronization reads from AD; replication or DNS faults corrupt or stall the sync. Verify: Run `dcdiag` and `repadmin /replsummary` on a domain controller with no errors; run `HYBID-Discovery.ps1`. Implement: Resolve AD replication, DNS, and time-sync issues before synchronizing.

G6. An Entra Connect host server

Description: A domain-joined Windows Server (2016+), patched, for Microsoft Entra Connect Sync (or a lightweight host with the Cloud Sync agent). Why: Connect Sync runs as a service on this host and must reach both AD and Entra ID. Verify: A supported, domain-joined server with TLS 1.2, .NET, and PowerShell available; run `HYBID-Discovery.ps1`. Implement: Provision a dedicated server (not a domain controller for production), patch it, and enable TLS 1.2.

G7. UPN / domain hygiene

Description: User principal names use a public, verified, routable domain (not `.local`). Why: A non-routable UPN suffix produces sign-in problems and `onmicrosoft.com` fallbacks in the cloud. Verify: Entra -> `Identity -> Settings -> Domain names` shows the public domain Verified; AD UPN suffixes match it; run `HYBID-Discovery.ps1`. Implement: Add and verify the public domain in Entra; add the matching UPN suffix in AD and update user UPNs.

G8. Network access to Microsoft cloud endpoints

Description: Outbound HTTPS (443) from the Connect host to Entra ID, plus required Microsoft 365 service URLs. Why: Synchronization, authentication-agent traffic, and tokens depend on these endpoints. Verify: From the Connect host, reach `https://login.microsoftonline.com` and the Microsoft 365 published URL/IP ranges. Implement: Allow the Microsoft 365 / Entra service URLs and IP ranges through the proxy/firewall.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

GCC High Parity & Compliance Notes — Passwordless & Passkey (FIDO2) Rollout

This is the **Government (GCC High)** edition of the passwordless/passkey solution. It mirrors the commercial phishing-resistant-MFA method exactly, adapted for Microsoft's **US Government national cloud** (Azure Government / GCC High). This note collects the national-cloud endpoints, the feature- parity items to verify, and the compliance/data-residency context specific to government tenants.

*Everything here is technical context for your operators and your ISSO/compliance team. Accreditation boundary and impact-level (IL) determinations are the **customer's** decision — this note provides the technical facts, not the authorization. Never assume commercial parity: **verify every capability against current Microsoft Government documentation.***

National cloud endpoints

The rollout is configured in the GCC High Entra admin center, users register at the GCC High security- info portal, and the included scripts target the US Gov cloud. Use these hosts in place of the commercial ones:

Purpose	Commercial	GCC High (this edition)	DoD (IL5) — verify
Sign-in / token host	`login.microsoftonline.com`	`login.microsoftonline.us`	`login.microsoftonline.us`
Microsoft Graph	`graph.microsoft.com`	`graph.microsoft.us`	`dod-graph.microsoft.us`
Microsoft Graph SDK env	`Global`	`-Environment USGov`	`-Environment USGovDoD`
Entra admin center	`entra.microsoft.com`	`entra.microsoft.us`	`entra.microsoft.us` (*verify*)
Security-info / My Sign-Ins (user registration)	`mysignins.microsoft.com` / `aka.ms/mysecurityinfo`	`mysignins.microsoft.us/security-info`	*verify current DoD URL*
M365 / admin center	`admin.microsoft.com`	`portal.office365.us` / GCC High admin center	*verify current GCC High URL*

All five PowerShell scripts (`ENTPASSKEYG-*`) connect with `Connect-MgGraph -Environment USGov`. Note the `ENTPASSKEYG-Set-ScopeTargeting.ps1` script builds `@odata.id` directory-object references against the national-cloud Graph host (`https://graph.microsoft.us/...`) — for DoD use `https://dod-graph.microsoft.us/...`. **Verify the correct cloud and endpoints for your specific tenant** — GCC High and DoD are distinct clouds.

Feature-parity considerations

GCC High and DoD frequently **lag commercial** on feature rollout, previews, and method availability, and some capabilities are unavailable. For a passwordless/passkey rollout specifically, confirm the following in *current Microsoft Government documentation* before relying on them — do **not** assume commercial parity:

- **Passkey (device-bound) in Microsoft Authenticator** — this is the newest and most likely-to-lag

capability. Device-bound passkey support, synced-passkey handling, and any preview flags **may be delayed or unavailable in GCC High/DoD.** *Verify the Passkey option is available under Authentication methods → Microsoft Authenticator in your cloud* before committing a wave to it. If unavailable, fall back to **FIDO2 security keys** (broadly supported) for that wave.

- **FIDO2 security keys** — generally available across clouds, but confirm attestation and AAGUID

key-restriction behavior in your government cloud. *Verify.*

- **Conditional Access authentication strengths** — the built-in **Phishing-resistant MFA** strength is

the enforcement control; *verify the built-in authentication-strength catalog and any custom-strength support in Azure Government.*

- **Registration campaign** — the nudge-to-register feature and its options may differ or lag in the

government cloud. *Verify availability and behavior.*

- **Temporary Access Pass (TAP)** — confirm TAP is available and its lifetime/one-time options behave as

documented in your cloud. *Verify.*

- **Graph API shapes / method** `@odata.type` **values** — how a passkey surfaces (as a `fido2AuthenticationMethod`

vs. a Microsoft Authenticator method) can vary by tenant, cloud, and API version; the adoption report accounts for both but *verify against your tenant.*

- **Entra ID P1/P2 licensing** — Conditional Access enforcement needs P1 (risk conditions need P2).

Government SKUs, availability, and bundling differ from commercial. *Verify P1/P2 availability for your GCC High (or DoD) tenant.*

Compliance & data-residency context (why GCC High)

GCC High exists so US public-sector and defense-industrial-base organizations can meet federal data-handling obligations that commercial Microsoft 365/Azure cannot. Phishing-resistant, passwordless authentication is not just good hygiene here — it is a **mandated control**:

- **OMB Memorandum M-22-09 — federal Zero Trust mandate.** *Moving the U.S. Government Toward Zero Trust

Cybersecurity Principles* **requires** agencies to enforce **phishing-resistant MFA** for staff, contractors, and partners, explicitly naming **FIDO2 / WebAuthn** and PIV as the acceptable methods. This rollout — FIDO2 security keys and passkeys enforced via the Conditional Access phishing-resistant authentication strength — is the direct technical implementation of that requirement. (M-22-09 is the primary government driver for this solution.)

- **FedRAMP High** — GCC High / Azure Government are designed to support FedRAMP High authorization

boundaries. Phishing-resistant MFA maps to the Identification & Authentication (IA) and Access Control (AC) control families an ISSO must evidence.

- **DoD Impact Levels (IL4 / IL5)** — Azure Government / GCC High and the DoD cloud support IL4 and IL5

workloads respectively. **Which impact level applies is the customer's ISSO/compliance determination.** For IL5, use the DoD endpoints (`dod-graph.microsoft.us`, `-Environment USGovDoD`) — *verify*.

- **CMMC 2.0** — for defense-industrial-base contractors, phishing-resistant authentication supports the

Identification & Authentication (IA) practices (multifactor and replay-resistant authentication for privileged and network access). This solution provides the technical control; your C3PAO assessor evaluates the practice.

- **ITAR / EAR data residency & US-persons handling** — GCC High provides US-sovereign data residency and

US-persons operational support, which is why organizations handling ITAR/EAR-controlled technical data choose it. Protecting sign-in to that environment with phishing-resistant credentials is exactly what this rollout does. *Confirm your data-residency and US-persons obligations with your compliance team.*

Determinations of accreditation boundary, impact level, control applicability, and which apps/users are in scope are the customer's ISSO/compliance and business decision. This solution supplies the technical implementation and evidence (methods-policy discovery, adoption reporting, enforcement validation) — not the authorization.

DoD (IL5) note

Where a tenant operates at **DoD IL5** rather than GCC High, the cloud and endpoints differ:

- Microsoft Graph host: `dod-graph.microsoft.us` (not `graph.microsoft.us`).
- Graph SDK: `Connect-MgGraph -Environment USGovDoD`; the `@odata.id` directory-object references in

`ENTPASSKEYG-Set-ScopeTargeting.ps1` must use `https://dod-graph.microsoft.us`.

- Confirm the correct Entra admin center / security-info portal URLs and passkey/FIDO2 method

availability for the DoD cloud — DoD feature availability can differ from GCC High and change over time.

All of the above is **"verify against current Microsoft Government documentation."**

3. Implementation Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

This is the **Government (GCC High)** edition: it mirrors the commercial passwordless method, adapted for Microsoft's US Government national cloud (Azure Government / GCC High). Follow these steps in order. Most steps are in the **GCC High Microsoft Entra admin center** (`https://entra.microsoft.us`); end-user credential registration is at the **GCC High security-info portal** (`https://mysignins.microsoft.us/security-info`); discovery, reporting, validation, and the safe methods-policy change use the included scripts, which target the US Gov cloud (`Connect-MgGraph -Environment USGov`). *Verify the current GCC High portal URLs against Microsoft Government documentation — DoD (IL5) tenants use different endpoints (see `gcc-high-parity-notes.md`).*

> *Model: assess current methods and adoption, enable the passwordless methods and Temporary Access Pass for a pilot group, drive registration with a campaign, require phishing-resistant MFA for*

*admins/sensitive apps in **report-only** first, validate, then expand in waves and only then retire the weak methods. Every change is targeted at a group, staged, and reversible; break-glass accounts are excluded from the enforcement policies throughout.*

Object naming convention (used everywhere below and in the scripts): `<Purpose> - <Scope> - <Stage>`**.** Create these once and reuse the exact names in testing, troubleshooting, and scripts:

Object	Name
Pilot users group	`Passwordless Rollout - Pilot - Pilot`
Pilot admins group	`Passwordless Rollout - Admins - Pilot`
Expansion wave group (repeat per wave)	`Passwordless Rollout - Wave1 - Expand`
Registration campaign scope	`Passwordless Registration Campaign - Pilot - Pilot`
CA policy — admins	`Require Phishing-Resistant MFA - Admins - Report-Only` (later `- Enforce`)
CA policy — sensitive apps	`Require Phishing-Resistant MFA - SensitiveApps - Report-Only` (later `- Enforce`)

Step 1 — Create the rollout and campaign groups

1. Entra -> `Identity -> Groups -> All groups -> New group` -> Security -> `Passwordless Rollout - Pilot - Pilot`; add a few representative users. Create.

1. Repeat for `Passwordless Rollout - Admins - Pilot` (the pilot administrators), `Passwordless Registration Campaign - Pilot - Pilot`, and the first expansion wave `Passwordless Rollout - Wave1 - Expand`.

1. Or run `ENTPASSKEYG-Set-ScopeTargeting.ps1` to create and populate the groups and preview membership before you commit.

Step 2 — Assess the current state (baseline)

1. Run `ENTPASSKEYG-Discovery.ps1`. It reports, read-only: which authentication methods are enabled and to whom they are targeted, whether FIDO2 / Passkey (Authenticator) / TAP are on, whether the weak methods (SMS, Voice) are still enabled, and the current CA policies that require MFA.

1. Run `ENTPASSKEYG-Report.ps1` for the adoption baseline — who is already registered for a phishing-resistant method versus who is still on password + weak MFA. Save both outputs; they are your before picture.

Step 3 — Enable Temporary Access Pass (the safety net first)

1. Entra -> `Identity -> Protection -> Authentication methods -> Policies -> Temporary Access Pass`.

2. Set to `Enable`, target the recovery operators (help desk / `Passwordless Rollout - Admins - Pilot`), and set a sensible lifetime and one-time/multi-use option. Save.

1. TAP is enabled *before* passwordless so a user always has a supported way to bootstrap or recover a credential without a password.

Step 4 — Enable the passwordless methods for the pilot

1. Entra -> `Identity -> Protection -> Authentication methods -> Policies -> FIDO2 security key` ->

`Enable`; under `Target`, select `Passwordless Rollout - Admins - Pilot` (and the pilot group). Under `Configure`, set `Allow self-service set up = Yes`; set `Enforce attestation` and `Enforce key restrictions` per your policy (allow-list your vetted AAGUIDs from requirement 2.3 if you are restricting key models). Save.

1. `Passkey (FIDO2)` / Microsoft Authenticator passwordless method -> `Enable` -> target `Passwordless Rollout - Pilot - Pilot`. *Verify current passkey options and any preview status in your tenant* before choosing device-bound settings. Save.

1. Optionally run `ENTPASSKEYG-Set-MethodsPolicy.ps1` (preview by default, `-WhatIf`) to apply the same enablement + targeting from PowerShell; review the preview, then re-run with `-WhatIf:$false`.

1. **Do not disable SMS or Voice yet** — retirement is Step 9, after adoption is proven.

Step 5 — Turn on the registration campaign for the pilot

1. Entra -> `Identity -> Protection -> Authentication methods -> Registration campaign`.

2. Set `State = Enabled`, choose to nudge users toward the passkey/Authenticator method, and target `Passwordless Registration Campaign - Pilot - Pilot`. Set the snooze/`days allowed to snooze` value. Save.

1. Send the pilot the onboarding comms (a short "you'll be asked to set up a passkey — here's how" email and a one-page how-to). Clear comms are what make adoption self-service instead of a ticket queue.

Step 6 — Require phishing-resistant MFA for admins (report-only first)

1. Entra -> `Identity -> Protection -> Conditional Access -> Policies -> New policy` named `Require Phishing-Resistant MFA - Admins - Report-Only`.

1. `Users`: include the directory roles / `Passwordless Rollout - Admins - Pilot`; **exclude the two break-glass accounts** (and any service accounts that cannot use passwordless).

1. `Target resources`: `All cloud apps` (or the admin/portal apps you scope to first).

2. `Grant`: `Grant access -> Require authentication strength -> Phishing-resistant MFA`.

3. Set `Enable policy = Report-only`. Create. Report-only evaluates the policy and logs what it

would do without blocking anyone.

1. Create a second policy `Require Phishing-Resistant MFA - SensitiveApps - Report-Only` the same way,

scoped to the sensitive apps from requirement 2.7 and the users who reach them, also in report-only.

Step 7 — Pilot: register and sign in passwordless

1. Pilot admins register a FIDO2 security key at the GCC High security-info portal

(`https://mysignins.microsoft.us/security-info`) -> `Add sign-in method -> Security key` (use a TAP if they have no other method yet). *Verify the current GCC High URL.*

1. Pilot users register a passkey in Microsoft Authenticator (`Add sign-in method -> Passkey`),

prompted by the registration campaign.

1. Each pilot user signs out and signs back in using the passwordless credential to confirm the

end-to-end flow works. Complete the Testing Guide.

Step 8 — Validate the pilot

1. Run `ENTPASSKEYG-Validate.ps1` -> confirms FIDO2 and Passkey (Authenticator) are enabled and

targeted, TAP is enabled, the CA policies exist with the phishing-resistant strength and the break-glass exclusion, and (report-only) that the policies are evaluating.

1. Review the report-only impact in `Conditional Access -> Insights and reporting` (and

`ENTPASSKEYG-Report.ps1`): confirm the admins policy would have required phishing-resistant MFA and would **not** have blocked the break-glass accounts. Only proceed to enforce when the pilot passes.

Step 9 — Enforce for admins, then expand in waves

1. Flip `Require Phishing-Resistant MFA - Admins - Report-Only` to `Enable policy = On` (rename the

`- Report-Only` suffix to `- Enforce`). Admin access is now passwordless-only. Do the same for the sensitive-apps policy once its report-only data is clean.

1. For each expansion wave: add the wave group (for example `Passwordless Rollout - Wave1 - Expand`)

to the FIDO2/passkey method targeting and to the registration campaign, send that wave's comms, let them register, then bring them into the phishing-resistant CA scope in report-only -> validate -> enforce. Repeat wave by wave.

1. **Retire the weak methods last.** Once a wave's adoption is high (from `ENTPASSKEYG-Report.ps1`),

scope SMS and Voice *out* for that group in the authentication methods policy. Never retire a weak method for users who have not yet registered a stronger one — that is the classic lock-out.

Step 10 — Operate the recovery runbook

1. Lost/broken key or replaced phone: the help desk verifies the user's identity, revokes the lost

credential (`My Security info` / admin removes the method), issues a **Temporary Access Pass**, and the user re-registers a new passkey/key. Document each step (see the lost-key runbook in Best Practices).

Order of operations

```
Groups -> assess -> enable TAP -> enable FIDO2/passkey (pilot) -> registration campaign -> CA phishing-resistant (report-only) -> pilot register/sign-in -> validate -> enforce + expand in waves -> retire weak methods last -> operate recovery
```

Rollback

• Method enablement: set the method back to `Disable` or remove the group from `Target` in the

authentication methods policy (immediate).

• Registration campaign: set `State = Disabled` (immediate; users already registered keep their

credential).

• CA policy: set `Enable policy = Report-only` or `Off`, or delete the policy — enforcement stops at

once. Because every enforce step follows a clean report-only pilot and break-glass is always excluded, a bad policy never locks out admins.

• Weak-method retirement: re-add the group to SMS/Voice targeting to restore the fallback while you

investigate.

5. Testing Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

Run after the pilot configuration applies (Implementation Step 7) and again before each enforce step. Scripts are referenced by name; all reads are read-only. This is the **Government (GCC High)** edition — portals are the GCC High endpoints and scripts target the US Gov cloud (`-Environment USGov`). Where a passkey/FIDO2 method appears unavailable, *verify GCC High/DoD availability against current Microsoft Government documentation* (see `gcc-high-parity-notes.md`).

Test 1 — Methods policy is correct

Do: Run `ENTPASSKEYG-Discovery.ps1`. Expected: FIDO2 security key and Passkey (Authenticator) are **enabled** and targeted at the pilot groups; Temporary Access Pass is **enabled** and scoped to recovery operators; SMS and Voice are **still enabled** (retirement is later). No method is enabled for `All users` prematurely.

Test 2 — Temporary Access Pass can be issued and used

Do: An `Authentication Administrator` issues a TAP for a test pilot user (`Users -> user -> Authentication methods -> Add -> Temporary Access Pass`); the user signs in with it and registers a passkey. Expected: The TAP works once (or per its setting), lets the user register a passwordless credential, and does not linger past its lifetime.

Test 3 — FIDO2 security key registration and sign-in

Do: A pilot admin registers a FIDO2 key at the GCC High security-info portal (`https://mysignins.microsoft.us/security-info`), signs out, and signs back in with the key. *Verify the current GCC High URL.* Expected: Registration completes (attestation/key-restriction rules honored if set); sign-in succeeds with the key and a local gesture — no password entered.

Test 4 — Passkey (Authenticator) registration and sign-in

Do: A pilot user registers a passkey in Microsoft Authenticator (prompted by the campaign), then signs in passwordless. Expected: The passkey registers and sign-in completes with the phone gesture. *If the passkey option is absent, verify the method's availability/preview status in your tenant and Authenticator version.*

Test 5 — Registration campaign nudges the pilot

Do: A pilot user in `Passwordless Registration Campaign - Pilot - Pilot` signs in interactively. Expected: They are prompted to set up the passkey/Authenticator method (with the configured snooze), and can complete it inline.

Test 6 — Phishing-resistant CA policy evaluates (report-only)

Do: Run `ENTPASSKEYG-Validate.ps1`; review `Conditional Access -> Insights and reporting` and `ENTPASSKEYG-Report.ps1` for the report-only result of `Require Phishing-Resistant MFA - Admins - Report-Only`. Expected: For a pilot admin the policy shows it **would require** phishing-resistant MFA; for the break-glass accounts it shows **not applied / excluded**. No user is actually blocked yet.

Test 7 — Enforcement requires phishing-resistant MFA

Do: After flipping the admins policy to `Enforce`, have a pilot admin attempt sign-in with only a weak method (for example password + SMS) to a targeted app. Expected: Access is blocked until they use the FIDO2 key or passkey; the same admin succeeds with the phishing-resistant credential.

Test 8 — Break-glass is never blocked

Do: Sign in with a break-glass account against the enforced policy scope (in a controlled test). Expected: The break-glass account is excluded and signs in — confirming the rollout cannot lock out emergency access.

Test 9 — Adoption is measurable

Do: Run `ENTPASSKEYG-Report.ps1`. Expected: A per-group breakdown of who has registered a phishing-resistant method versus who is still on password + weak MFA — the number you gate weak-method retirement on.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1-6 and 8 pass; pilot admins and users sign in passwordless; the CA policy is clean in report-only and excludes break-glass
Enforce pass	Test 7 passes for admins; Test 8 still passes; sensitive-apps policy report-only is clean
Expand/retire pass	Test 9 shows high adoption for a wave before SMS/Voice are scoped out for that wave; no lock-outs after retirement

6. Troubleshooting Guide — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra

Use `ENTPASSKEYG-Discovery.ps1` for the methods-policy state, `ENTPASSKEYG-Report.ps1` for adoption, `ENTPASSKEYG-Validate.ps1` for the enforcement controls, and the portal `Conditional Access -> Insights and reporting` for report-only impact.

A. Discovery or validation errors

Symptom	Cause	Remediation
`Connect-MgGraph` fails or scopes missing	SDK not installed, or read scopes not consented	`Install-Module Microsoft.Graph -Scope CurrentUser`; re-run and accept `Policy.Read.All` (and `UserAuthenticationMethod.Read.All` for the report)

Symptom	Cause	Remediation
Auth/endpoint errors, or connects to the wrong tenant/cloud	Connected to the commercial cloud instead of US Gov	Use `Connect-MgGraph -Environment USGov` (GCC High → `login.microsoftonline.us` / `graph.microsoft.us`). For DoD (IL5) use `-Environment USGovDoD` (`dod-graph.microsoft.us`). *Verify the correct cloud for your tenant.*
Empty method list	Signed in to the wrong tenant, or lacking `Authentication Policy Administrator` read	Confirm the tenant; ensure the operator can read the authentication methods policy
CA policies not listed	The operator cannot read Conditional Access	Add `Security Reader` / `Conditional Access Administrator`

B. The passkey (Authenticator) option is missing

• The Passkey option under Microsoft Authenticator may be in preview or gated by tenant configuration,

and passkey / FIDO2 method availability in GCC High and DoD can lag the commercial cloud. *Verify current availability and any preview status for your GCC High (or DoD) tenant against current Microsoft Government documentation* under `Authentication methods -> Policies -> Microsoft Authenticator` — do not assume commercial parity. Confirm users are on the latest Authenticator and a supported device OS. If the device-bound passkey path is unavailable in your cloud, use FIDO2 security keys for that wave while you confirm availability.

C. FIDO2 security-key registration fails

Symptom	Cause	Remediation
"This security key isn't allowed"	Key restrictions / AAGUID allow-list excludes the key model	Add the key's AAGUID to the allow-list, or relax `Enforce key restrictions`, in the FIDO2 method `Configure` blade
Registration blocked with no other method	User has no existing credential to register with	Issue a Temporary Access Pass so the user can bootstrap the key
Attestation error	`Enforce attestation` on, key provides none	Use an attestation-capable key, or relax attestation per your policy

D. User can't register — no way to start

• This is why TAP is enabled first. Issue a Temporary Access Pass (`Users -> user `-> Authentication methods -> Add -> Temporary Access Pass), which lets the user sign in without a password and add a FIDO2 key or passkey. Confirm TAP is enabled and the user is in its target scope (ENTPASSKEYG-Validate.ps1`).

E. Registration campaign not prompting

- Confirm `Authentication methods -> Registration campaign -> State = Enabled` and the user is in

`Passwordless Registration Campaign - Pilot - Pilot`. The nudge appears on interactive sign-in only, respects the snooze count, and does not prompt users who already have the target method. It will not prompt during non-interactive or app-token flows.

F. Conditional Access policy blocks the wrong people (or nobody)

Symptom	Cause	Remediation
A user is unexpectedly blocked after enforce	They had not registered a phishing-resistant method before the policy was turned on	Return the policy to `Report-only`, confirm adoption with `ENTPASSKEYG-Report.ps1`, register the user (TAP if needed), then re-enforce
Policy has no effect after enforce	Left in `Report-only`, or scope/exclusions wrong	Set `Enable policy = On`; check the user is in the include scope and not excluded
Admins locked out risk	Break-glass not excluded	Always exclude the two break-glass accounts; `ENTPASSKEYG-Validate.ps1` flags a policy that does not

G. "Authentication strength" not requiring passwordless

- Confirm the grant control is `Require authentication strength -> Phishing-resistant MFA` (the

built-in strength), not the generic `Require multifactor authentication` (which still accepts phishable methods). `ENTPASSKEYG-Validate.ps1` notes policies using built-in MFA instead of the phishing-resistant strength.

H. Weak-method retirement caused lock-outs

- SMS/Voice were scoped out for a group before its users registered a stronger method. Re-add the

group to SMS/Voice targeting to restore the fallback immediately, then drive registration and only retire again once `ENTPASSKEYG-Report.ps1` shows high adoption for that group.

I. Diagnostics quick reference

```
# US Government cloud (GCC High). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us).
Connect-MgGraph -Environment USGov -Scopes 'Policy.Read.All','UserAuthenticationMethod.Read.All' -NoWelcom
# methods policy state
(Invoke-MgGraphRequest -Method GET -Uri '/v1.0/policies/authenticationMethodsPolicy').authenticationMethod
  Select-Object id, state
# a user's registered methods
```

```
(Invoke-MgGraphRequest -Method GET -Uri "/v1.0/users/<upn>/authentication/methods").value.'@odata.type'
# phishing-resistant CA policies
(Invoke-MgGraphRequest -Method GET -Uri '/v1.0/identity/conditionalAccess/policies').value |
  Where-Object { $_.grantControls.authenticationStrength.id } | Select-Object displayName, state
```

J. When to escalate

If a lost or stolen FIDO2 key or a compromised device is suspected, treat it as an incident: revoke the credential immediately (`Users` -> user -> `Authentication methods` -> remove the key/passkey), review the user's recent sign-ins, issue a fresh TAP only after verifying identity, and engage your incident-response process. If admin sign-in is disrupted tenant-wide, use a break-glass account and set the enforcing CA policy to `Report-only` while you investigate.

7. Best Practices — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra

• Enable the safety net before the credential. Turn on Temporary Access Pass *first*, so every user always has a supported, password-free way to bootstrap and recover a passwordless credential. A rollout without a recovery path becomes a lock-out.

• Retire weak methods last, and only after adoption. Never scope SMS or Voice out for a group before that group has registered a stronger method — gate retirement on the adoption number from `ENTPASSKEYG-Report.ps1`. This is the single most common way passwordless rollouts lock people out.

• Admins and sensitive apps go phishing-resistant first. Privileged accounts are the highest-value targets; require the `Phishing-resistant MFA` authentication strength for them before you widen the scope, so the blast radius shrinks immediately.

• Always pilot in report-only. Every Conditional Access enforcement starts as `Report-only`; read the impact in `Insights and reporting` and confirm it would not block break-glass before you turn it on.

• Keep break-glass excluded, always. Exclude the two cloud-only emergency accounts from every phishing-resistant CA policy, monitor their sign-ins, and test that they are never blocked (Testing Test 8).

• Prefer FIDO2 keys for admins and shared devices; passkeys for the workforce. A portable hardware key suits people who move between machines or use kiosks; a device-bound passkey in Authenticator is the lowest-friction option for users who already carry a phone.

• Consider key restrictions deliberately. AAGUID allow-listing lets you accept only vetted key models, but maintain the list — an over-tight restriction blocks legitimate new keys. Enforce attestation where your policy requires provenance.

• Roll out in waves, not big-bang. Enable -> register (campaign) -> report-only -> validate -> enforce for one group, then repeat. Repeat buyers recognize the same pattern each wave, which keeps it low-risk.

• Communicate before you nudge. Send each wave a short "you'll be asked to set up a passkey" note and

a one-page how-to before the registration campaign hits them; clear comms turn adoption into self-service instead of help-desk tickets.

• Verify preview/availability before you commit. Passkey behavior in Authenticator has shipped and changed on Microsoft's schedule — confirm the method's current state and any preview flag in your tenant before committing a wave to a specific passkey type.

• Operate the lost-key runbook consistently. Verify identity -> revoke the lost credential -> issue a TAP -> re-register -> record it. A written, repeatable recovery process keeps the help desk fast and safe.

• Make it recurring. Re-run `ENTPASSKEYG-Discovery.ps1` and `ENTPASSKEYG-Report.ps1` on a cadence so new users, drifted method settings, and stalled adoption are caught as they appear.

Where to go next

• **Zero Trust Architecture — Conditional Access Baseline & Rollout** — build the full persona-based Conditional Access baseline that this phishing-resistant requirement slots into.

• **Enterprise App & Service Principal Governance** — close the OAuth consent-phishing foothold that survives even strong sign-in.

• **Privileged Identity Management (PIM)** and **Identity Protection risk policies** — pair passwordless admins with just-in-time elevation and risk-based access for a complete privileged access story.

8. Deliverables Summary — Passwordless & Passkey (FIDO2) Rollout for Microsoft Entra — Government (GCC High)

> ***Government (GCC High) edition*** *— the commercial passwordless/passkey solution adapted for Microsoft's US Government national cloud (Azure Government / GCC High), with US Gov portals/endpoints and a dedicated national-cloud parity + compliance note. Satisfies the OMB M-22-09 phishing-resistant MFA mandate and CMMC 2.0 authentication drivers. For US public-sector and defense-industrial-base tenants.*

Documentation

Document	Purpose
Executive Summary	Business case and what is in the box
GCC High Parity & Compliance Notes	National-cloud endpoints, GCC High/DoD passkey/FIDO2 feature-parity considerations, and FedRAMP High / DoD IL4-IL5 / CMMC 2.0 / OMB M-22-09 / ITAR context (`gcc-high-parity-notes.md`)

Document	Purpose
1. Solution Overview	How passwordless works in Entra — FIDO2/WebAuthn, passkeys vs. security keys, the authentication methods policy, registration campaign, and phishing-resistant Conditional Access
2. Requirements Guide	Every solution-specific prerequisite with Verify / Implement-if-missing
Global Requirements (Entra ID Solutions)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps (groups, assess, TAP, enable FIDO2/passkey, registration campaign, phishing-resistant CA report-only, pilot, validate, enforce + expand in waves, retire weak methods last, recovery)
5. Testing Guide	Validation procedures with pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations + where to go next

PowerShell scripts

Script	What it does
`ENTPASSKEYG-Discovery.ps1`	Reads the authentication methods policy — which methods are enabled and targeted (FIDO2, Passkey/Authenticator, TAP, SMS, Voice), the registration campaign state, and the CA policies requiring MFA (read-only)
`ENTPASSKEYG-Validate.ps1`	Confirms FIDO2 + Passkey are enabled/targeted, TAP is enabled, the phishing-resistant CA policies exist with break-glass excluded, and (report-only) that they evaluate (read-only)
`ENTPASSKEYG-Report.ps1`	Passwordless adoption report — per group, who has registered a phishing-resistant method versus who is still on password + weak MFA; the number that gates weak-method retirement (read-only)
`ENTPASSKEYG-Set-MethodsPolicy.ps1`	Safely enables FIDO2 + Passkey (Authenticator) and targets them at the rollout groups; `-WhatIf` by default (preview), gated apply
`ENTPASSKEYG-Set-ScopeTargeting.ps1`	Builds and previews the pilot / admin / wave / registration-campaign groups

What the buyer receives

- This implementation guide as a Word document and PDF.

- All five PowerShell scripts in a single ZIP.
- A repeatable process: Assess -> Configure -> Pilot -> Validate -> Expand.

Delivered as a Complete Solution Package (PDF + Word + scripts).

Outcome

Phishing-resistant, passwordless sign-in across the tenant — admins and sensitive apps passwordless first, weak methods retired only after adoption, and a Temporary Access Pass + lost-key runbook so the rollout never locks anyone out.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

ENTPASSKEYG-Discovery.ps1

Purpose: Read-only assessment of the current passwordless posture: which authentication methods are enabled and to whom they are targeted (FIDO2 security key, Passkey/Microsoft Authenticator, Temporary Access Pass, and the weak methods SMS and Voice), the registration-campaign state, and the Conditional Access policies that require MFA. This is your before baseline. HOW TO RUN Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Discovery.ps1 Consents to Policy.Read.All (read-only). No changes are made. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS A per-method enabled/targeted listing, the registration campaign state, and a list of CA policies that apply an MFA / authentication-strength grant. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string]$CsvPath)

How to run: Install-Module Microsoft.Graph -Scope CurrentUser # once powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Discovery.ps1 Consents to Policy.Read.All (read-only). No changes are made. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS A per-method enabled/targeted listing, the registration campaign state, and a list of CA policies that apply an MFA / authentication-strength grant. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string]$CsvPath)

ENTPASSKEYG-Report.ps1

Purpose: Read-only adoption report. For each user it reads the registered authentication methods and classifies them as phishing-resistant (FIDO2 security key or passkey in Authenticator) versus still relying on password + weak MFA (SMS / voice / phone). Optionally scoped to a rollout group so you can gate weak-method retirement on that wave's adoption number. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Report.ps1 Optional: -GroupId <objectId> to report only that group's members (a rollout wave). Optional: -CsvPath .\passkey-adoption.csv to export. Consents to UserAuthenticationMethod.Read.All, User.Read.All, GroupMember.Read.All (read-only). GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS Per-user phishing-resistant vs. weak classification and a summary adoption percentage. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string]$GroupId, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Report.ps1 Optional: -GroupId <objectId> to report only that group's members (a rollout wave). Optional: -CsvPath .\passkey-adoption.csv to export. Consents to UserAuthenticationMethod.Read.All, User.Read.All, GroupMember.Read.All (read-only). GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS Per-user

phishing-resistant vs. weak classification and a summary adoption percentage. No changes are made. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string]$GroupId, [string]$CsvPath)

ENTPASSKEYG-Set-MethodsPolicy.ps1

Purpose: Enables the passwordless methods for the pilot in the authentication methods policy: FIDO2 security key and Microsoft Authenticator (passkey), targeted at the named rollout groups, and confirms Temporary Access Pass is enabled first. Defaults to -WhatIf, so a plain run only PREVIEWS the policy changes and changes nothing. This script does NOT disable SMS or Voice — weak-method retirement is a deliberate, adoption-gated portal step done LAST. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-MethodsPolicy.ps1 -Fido2GroupId <id> -PasskeyGroupId <id> Apply after review: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-MethodsPolicy.ps1 -Fido2GroupId <id> -PasskeyGroupId <id> -WhatIf:$false Consents to Policy.ReadWrite.AuthenticationMethod, Policy.Read.All. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS In preview: the method enable/target changes that WOULD be made. When applied: FIDO2 and Microsoft Authenticator are enabled and targeted at the supplied groups. Reversible in the portal (set the method back to Disabled or remove the group from Target). .NOTES White-label — Entra ID Solutions. Write action — preview (-WhatIf) by default. Does not retire weak methods. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory)] [string]$Fido2GroupId, [Parameter(Mandatory)] [string]$PasskeyGroupId)

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-MethodsPolicy.ps1 -Fido2GroupId <id> -PasskeyGroupId <id> Apply after review: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-MethodsPolicy.ps1 -Fido2GroupId <id> -PasskeyGroupId <id> -WhatIf:$false Consents to Policy.ReadWrite.AuthenticationMethod, Policy.Read.All. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS In preview: the method enable/target changes that WOULD be made. When applied: FIDO2 and Microsoft Authenticator are enabled and targeted at the supplied groups. Reversible in the portal (set the method back to Disabled or remove the group from Target). .NOTES White-label — Entra ID Solutions. Write action — preview (-WhatIf) by default. Does not retire weak methods. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'High')] param([Parameter(Mandatory)] [string]$Fido2GroupId, [Parameter(Mandatory)] [string]$PasskeyGroupId)

ENTPASSKEYG-Set-ScopeTargeting.ps1

Purpose: Creates (or previews) the security groups the rollout targets, following the naming convention <Purpose> - <Scope> - <Stage>: Passwordless Rollout - Pilot - Pilot Passwordless Rollout - Admins - Pilot Passwordless Rollout - Wave1 - Expand Passwordless Registration Campaign - Pilot - Pilot Defaults to -WhatIf (preview only). Optionally seeds members from a CSV of userPrincipalNames. HOW TO RUN Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-ScopeTargeting.ps1 Create the groups: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-ScopeTargeting.ps1 -WhatIf:$false Optional: -PilotMembersCsv .\pilot.csv (column: userPrincipalName) to add pilot members. Consents to Group.ReadWrite.All, User.Read.All. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For

DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS In preview: the groups that WOULD be created and members that WOULD be added. When applied: the groups exist and are populated. Idempotent — existing groups are reused, not duplicated. .NOTES White-label — Entra ID Solutions. Write action — preview (-WhatIf) by default. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string]$PilotMembersCsv)

How to run: Preview (default, no changes): powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-ScopeTargeting.ps1 Create the groups: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Set-ScopeTargeting.ps1 -WhatIf:$false Optional: -PilotMembersCsv .\pilot.csv (column: userPrincipalName) to add pilot members. Consents to Group.ReadWrite.All, User.Read.All. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS In preview: the groups that WOULD be created and members that WOULD be added. When applied: the groups exist and are populated. Idempotent — existing groups are reused, not duplicated. .NOTES White-label — Entra ID Solutions. Write action — preview (-WhatIf) by default. > [CmdletBinding(SupportsShouldProcess = $true, ConfirmImpact = 'Medium')] param([string]$PilotMembersCsv)

ENTPASSKEYG-Validate.ps1

Purpose: Read-only check that the rollout controls are in place: (1) FIDO2 security key and Passkey/Microsoft Authenticator are enabled and targeted; (2) Temporary Access Pass is enabled (the recovery safety net); (3) at least one Conditional Access policy applies the phishing-resistant authentication strength; and (4) the break-glass accounts are excluded from those CA policies. Prints PASS/WARN lines. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Validate.ps1 -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to Policy.Read.All, User.Read.All (read-only). No changes are made. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS PASS/WARN for each control and a warning if any phishing-resistant CA policy does NOT exclude a named break-glass account. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpn)

How to run: powershell -ExecutionPolicy Bypass -File .\ENTPASSKEYG-Validate.ps1 -BreakGlassUpn bg1@contoso.onmicrosoft.com,bg2@contoso.onmicrosoft.com Consents to Policy.Read.All, User.Read.All (read-only). No changes are made. GCC High / US Gov: Connect-MgGraph uses -Environment USGov (login.microsoftonline.us / graph.microsoft.us). For DoD (IL5) use -Environment USGovDoD (dod-graph.microsoft.us). *Verify the correct cloud for your tenant.* EXPECTED RESULTS PASS/WARN for each control and a warning if any phishing-resistant CA policy does NOT exclude a named break-glass account. Nothing is modified. .NOTES White-label — Entra ID Solutions. Read-only. > [CmdletBinding()] param([string[]]$BreakGlassUpn)